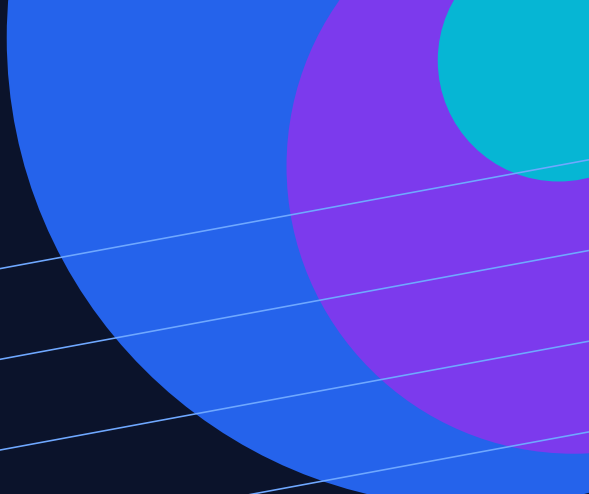




THREAT RESEARCH / DETECTION ENGINEERING

ClickFix Multi-Stage Execution via Pcalua

Hidden WMI process creation, remote WebDAV access and Rundll32 proxy execution

REPORT	STATUS	CONFIDENCE
Detection dossier	Production candidate	High

Prepared for defensive research and environment-specific validation. Source facts, analytical interpretation, assumptions and proposed detection logic are intentionally separated.

VERSION 1.0 / 22 JULY 2026

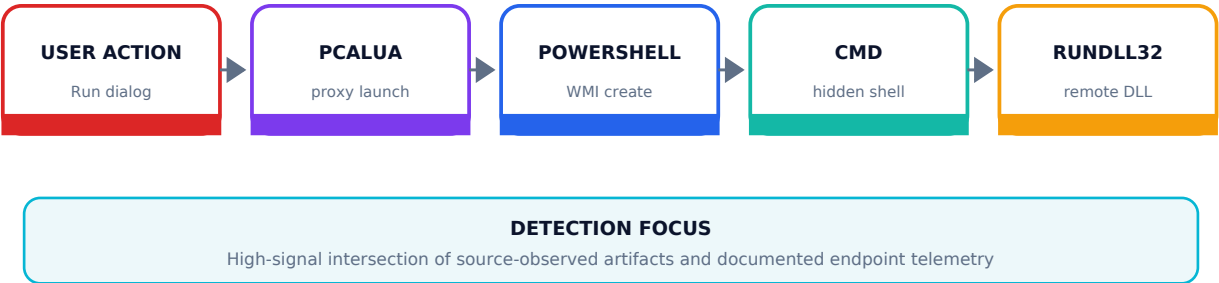
Executive Assessment

WHY THIS MATTERS

A confirmed incident exposed a highly distinctive command chain: Explorer-launched pcalua proxies PowerShell, PowerShell uses WMI to hide cmd.exe, and cmd executes rundll32 against a remote WebDAV path. The package generalizes the behavior while removing every environment-specific indicator.

Dimension	Assessment	Operational Implication
Observed behavior	pcalua.exe invoked PowerShell; WMI Win32_Process.Create launched hidden cmd.exe; rundll32 executed an ordinal export from a remotely accessed file.	Multiple evasive primitives coexist in one process command line, materially reducing benign overlap.
Detection posture	Production candidate	Alert only on the full intersection; use broader pcalua activity for investigation, not automatic incident creation.
Telemetry	Microsoft Defender XDR DeviceProcessEvents	One process-creation event can retain the embedded command chain and parent context.
Primary limitation	The rule is tied to a command construction, not to every ClickFix variant.	Renaming tools, changing WMI syntax or splitting stages can evade it.

Attack and observation flow



Evidence Model

Evidence class	Statement	Use in the package
Source fact	Microsoft documents ClickFix as user-driven execution through Run/Terminal/PowerShell and describes campaigns that ultimately launch DLLs through rundll32.exe.	Directly supports the selected behavior or artifact.
Documented telemetry	DeviceProcessEvents documents FileName, ProcessCommandLine, initiating-process fields, device/account context and hashes.	Supports the table, fields and investigation pivots.
Analytical interpretation	pcalua plus PowerShell WMI hidden-window creation plus rundll32 and a remote path is substantially more specific than any single LOLBin.	Defines why the intersection may be distinguishable.
Unvalidated assumption	The complete nested command remains visible in ProcessCommandLine and is not truncated or normalized.	Must be measured before deployment or promotion.

EVIDENCE BOUNDARY

This rule does not identify the original lure, prove clipboard use, or attribute activity to a named actor. It detects a multi-stage execution pattern compatible with the observed ClickFix incident.

Telemetry contract

Component	Requirement	Failure condition
Data source	Microsoft Defender XDR DeviceProcessEvents	MDE not deployed or DeviceProcessEvents unavailable.
Core fields	Timestamp, DeviceId, DeviceName, FileName, ProcessCommandLine, AccountName, InitiatingProcessFileName, SHA1, ReportId	Command line missing/truncated or parent context absent.
Time context	Single-event match; recommended analytics frequency PT5M with an environment-appropriate lookback.	Ingestion delay exceeds the configured lookback.

Detection Logic

HYPOTHESIS

If the same execution method is attempted, a pcalua.exe process event should contain PowerShell, WMI hidden-process primitives, rundll32 and a remote-path indicator in the same command line.

```
DeviceProcessEvents
| where Timestamp >= ago(1h)
| where FileName =~ "pcalua.exe"
| where ProcessCommandLine has "powershell"
| where ProcessCommandLine has_any ("Win32_ProcessStartup", "Win32_Process")
| where ProcessCommandLine has "ShowWindow=0"
| where ProcessCommandLine has "rundll32"
| where ProcessCommandLine has_any (@ "\\ ", @"@SSL\ ")
| project Timestamp, DeviceId, DeviceName, AccountName,
    ProcessCommandLine, InitiatingProcessFileName,
    InitiatingProcessCommandLine, SHA1, ReportId
```

Condition	Purpose	Durability
pcalua.exe	Selects the proxy-execution binary used in the observed chain.	Medium
PowerShell + WMI classes	Requires the nested process-creation mechanism.	Medium
ShowWindow=0	Captures explicit hidden-window configuration.	Medium
rundll32 + remote path	Captures remote payload proxy execution.	Medium

Analyst Triage

Priority	Question	Evidence to collect
1	Was the command user-launched from Explorer or the Run dialog?	Parent process, interactive account, RunMRU evidence.
2	What remote resource was mounted or accessed?	Defanged domain/path, DNS, network and WebClient/WebDAV telemetry.
3	What did rundll32 load?	File hash, signer, export ordinal, memory/EDR detections.
4	What followed execution?	Child processes, persistence, credential access and outbound traffic.

False-positive model

Scenario	Why it may match	Recommended handling
Compatibility troubleshooting	Administrators may legitimately run pcalua against an application.	Full WMI+rundll32+remote intersection should remain absent; investigate exceptions.
Software deployment	A wrapper could embed PowerShell or WMI.	Validate software owner, signer, package source and stable command line.
Red-team exercise	The chain may be intentionally reproduced.	Confirm authorization and preserve as a detection-control test.

NO PREMATURE ALLOWLISTING

Do not allowlist pcalua.exe, PowerShell, Explorer or rundll32 globally. Any exception should bind to an owned application, validated signer/path and exact approved command construction.

Validation Plan

Step	Action	Expected evidence
1	Run over 90 days.	Distinct command lines, parents, users and devices.
2	Replay a benign lab command preserving the relevant tokens.	End-to-end confirmation that the nested command is not truncated.
3	Inspect every historical result.	Owned software vs unexplained execution.
4	Measure analytics latency.	Lookback safely exceeds worst-case ingestion delay.

Decision	Criterion
Promote / retain	Zero benign recurrence or deterministic separation of authorized tooling.
Tune	Restrict with validated signer, path or approved parent only after evidence.
Reject	Legitimate tooling regularly produces an indistinguishable complete chain or command-line visibility is unreliable.

OPERATING NOTE

The exact external domain, host and remote file path from the incident are intentionally absent. IOC pivots belong in private incident content, not in this public behavioral package.

ATT&CK; Mapping & References

Technique	Relationship	Mapping posture
T1202 - Indirect Command Execution	pcalua proxies execution of another program.	Direct primitive.
T1047 - Windows Management Instrumentation	PowerShell invokes Win32_Process.Create.	Direct primitive.
T1218.011 - Rundll32	rundll32 proxies DLL export execution.	Direct primitive.
T1059.001 - PowerShell	PowerShell constructs the hidden process chain.	Direct primitive.

Primary and authoritative references

1. Microsoft Threat Intelligence - Think before you Click(Fix)
<https://www.microsoft.com/en-us/security/blog/2025/08/21/think-before-you-clickfix-analyzing-the-clickfix-social-engineering-technique/>
2. Microsoft Learn - DeviceProcessEvents schema
<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
3. LOLBAS - Pcalua
<https://lolbas-project.github.io/lolbas/Binaries/Pcalua/>
4. MITRE ATT&CK; - Rundll32
<https://attack.mitre.org/techniques/T1218/011/>

DOCUMENT STATUS

Research-derived and unvalidated in the target environment. The package is suitable for controlled testing and analyst review; it is not evidence that a specific environment is compromised.